DG INTERNS HUB | CYBERSECURITY INTERNSHIP

OWASP ZAP Scan Report

Web Security & Vulnerability Testing (VAPT Basics)

Tool	OWASP ZAP by Checkmarx
Tool version	2.17.0
Target	http://127.0.0.1
Original report generated	13 October 2026, 05:28:52 (as displayed in source report)
Report status	**PARTIAL SCAN** — scan stopped before completion
Internship	DG Interns Hub Cybersecurity Internship — Week 6
Prepared for	Samyuktha S. | DG/SEPTEMBER/CYBER/102

IMPORTANT SCOPE NOTE

This document reorganizes the presentation of the supplied scan report. The original eight-page ZAP report is appended unchanged as the evidence appendix. The scan was stopped before completion; results represent observations recorded up to that point.

1. Report overview

This report presents the observations contained in the supplied OWASP ZAP by Checkmarx scan export for the local target **http://127.0.0.1**. The source identifies ZAP version **2.17.0** and lists 13 alerts across Medium, Low, and Informational risk categories. The scan was stopped before completion, so this is a partial snapshot rather than a complete assessment.

2. Assessment objective

Organize and document the automated scan output for internship review while preserving the original alert classifications and evidence. Automated alerts are signals for triage; their presence alone does not establish exploitability or confirm a vulnerability in context.

3. Target and testing environment

Field	Source value
Target site	http://127.0.0.1
Contexts	No contexts were selected; all contexts were included by default.
Risk levels included	High, Medium, Low, Informational
Risk levels excluded	None
Confidence levels included	User Confirmed, High, Medium, Low
Confidence levels excluded	User Confirmed, High, Medium, Low, False Positive

4. Tool information — OWASP ZAP

The source report identifies “ZAP by Checkmarx” version 2.17.0. The original report's alert names, descriptions, evidence, URLs, solutions, and references are retained in the appended source-report pages. Where the scan export does not provide a detail in its summary, this enhanced front matter does not infer it.

5. Scan methodology and scope

The included site was the local address above. The source states that no contexts were selected, so all contexts were included by default. This enhanced report does not add tests or imply that manual validation was performed. Because the scan was stopped before completion, paths or issues not seen before stopping may be absent.

6. Scan summary

Counts below are transcribed from the original report's “Alert Counts by Risk and Confidence” table (source PDF, page 2).

Risk level	High confidence	Medium confidence	Total
High	0	0	0
Medium	2	3	5
Low	2	3	5
Informational	1	2	3
Total	**5**	**8**	**13**

Source summary metric	Count	Interpretation
Total alerts	13	All risk categories included in the report summary.
High risk	0	No High-risk alerts are listed in this partial scan; this does not prove the target is secure.
Medium risk	5	Two High-confidence and three Medium-confidence alerts.
Low risk	5	Two High-confidence and three Medium-confidence alerts.
Informational	3	One High-confidence and two Medium-confidence alerts.
High confidence	5	2 Medium-risk + 2 Low-risk + 1 Informational.
Medium confidence	8	3 Medium-risk + 3 Low-risk + 2 Informational.

7. Alert summary by risk and confidence

The source report contains six alert groups: Medium / High confidence (2); Medium / Medium confidence (3); Low / High confidence (2); Low / Medium confidence (3); Informational / High confidence (1); Informational / Medium confidence (2). No High-risk alerts appear in the summary table.

8. Detailed alert analysis

The original ZAP pages are included after this enhanced overview. They preserve the source alert list and the technical details supplied by the scanner, including affected URLs, evidence, descriptions, solutions, and references where provided. Use those original pages as the primary technical record.

9. Recommendations and remediation

The source report includes ZAP-provided solutions and references for individual alert types in the appended pages. Follow those alert-specific recommendations after confirming applicability to the target. General process recommendations for this partial scan are:

• Manually validate each relevant alert against the exact URL and request/response context.
• Record reproduction steps and distinguish confirmed behavior from scanner-generated suspicion.
• Prioritize remediation based on validated impact, exposure, and business context—not risk label alone.
• Re-run the scan after remediation and allow the scan to complete where feasible; compare results with this partial snapshot.
• Keep evidence, target scope, tool version, and scan limitations alongside the final submission.

These are workflow recommendations, not claims that the listed issues have been manually verified or fixed.

10. Scan limitations

• The scan was stopped before completion; the report reflects alerts observed up to that point.
• Automated alerts can include findings that require context, manual verification, or may not be exploitable.
• A zero-High-risk count does not establish that the target is secure.
• No production system is represented: the target in the source report is http://127.0.0.1.
• The source export does not document a complete manual validation exercise; any missing details should be treated as “Not provided in the original scan report.”

11. Conclusion

The supplied OWASP ZAP report records 13 alerts for http://127.0.0.1: five Medium, five Low, and three Informational, with five High-confidence and eight Medium-confidence alerts. These totals match the original risk/confidence table. Because the scan was partial and alerts have not all been manually validated, the results should be treated as preliminary assessment evidence. Complete the scan if possible, validate relevant alerts, remediate confirmed issues, and retest.

Evidence appendix

The following eight pages are the original uploaded OWASP ZAP PDF pages appended unchanged to preserve source evidence and technical detail.

ZAP by Checkmarx Scanning Report

Generated with The ZAP logoZAP on Tue 13 Oct 2026, at 05:28:52

ZAP Version: 2.17.0

ZAP by Checkmarx

Contents

1. About This Report
    1. Report Parameters
2. Summaries
    1. Alert Counts by Risk and Confidence
    2. Alert Counts by Site and Risk
    3. Alert Counts by Alert Type
    4. Insights
3. Alerts
    1. Risk=Medium, Confidence=High (2)
    2. Risk=Medium, Confidence=Medium (3)
    3. Risk=Low, Confidence=High (2)
    4. Risk=Low, Confidence=Medium (3)
    5. Risk=Informational, Confidence=High (1)
    6. Risk=Informational, Confidence=Medium (2)
4. Appendix
    1. Alert Types

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- http://127.0.0.1

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: High, Medium, Low, Informational

Excluded: None

Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
		User Confirmed	**High**	**Medium**	**Low**	**Total**
Risk	**High**	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)
	Medium	0 (0.0%)	2 (15.4%)	3 (23.1%)	0 (0.0%)	5 (38.5%)
	Low	0 (0.0%)	2 (15.4%)	3 (23.1%)	0 (0.0%)	5 (38.5%)
	Informational	0 (0.0%)	1 (7.7%)	2 (15.4%)	0 (0.0%)	3 (23.1%)
	Total	0 (0.0%)	5 (38.5%)	8 (61.5%)	0 (0.0%)	13 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
		High (= High)	**Medium (>= Medium)**	**Low (>= Low)**	**Informational (>= Informational)**
Site	**http://127.0.0.1**	0 (0)	4 (4)	5 (9)	3 (12)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Content Security Policy (CSP) Header Not Set	Medium	4 (30.8%)
Directory Browsing	Medium	3 (23.1%)
HTTP Only Site	Medium	1 (7.7%)
Hidden File Found	Medium	1 (7.7%)
Missing Anti-clickjacking Header	Medium	2 (15.4%)
Big Redirect Detected (Potential Sensitive Information Leak)	Low	1 (7.7%)
Cookie without SameSite Attribute	Low	1 (7.7%)
In Page Banner Information Leak	Low	2 (15.4%)
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	5 (38.5%)
X-Content-Type-Options Header Missing	Low	4 (30.8%)
Authentication Request Identified	Informational	1 (7.7%)
Session Management Response Identified	Informational	3 (23.1%)
User Agent Fuzzer	Informational	5 (38.5%)
Total		13

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	6
Low	Warning		ZAP warnings logged - see the zap.log file for details	2
Info	Informational		Percentage of network failures	3 %
Info	Informational	http://127.0.0.1	Percentage of responses with status code 2xx	58 %
Info	Informational	http://127.0.0.1	Percentage of responses with status code 3xx	35 %
Info	Exceeded Low	http://127.0.0.1	Percentage of responses with status code 4xx	6 %

Level	Reason	Site	Description	Statistic
Info	Informational	http://127.0.0.1	Percentage of endpoints with content type image/png	7 %
Info	Informational	http://127.0.0.1	Percentage of endpoints with content type text/css	7 %
Info	Informational	http://127.0.0.1	Percentage of endpoints with content type text/html	76 %
Info	Informational	http://127.0.0.1	Percentage of endpoints with method GET	92 %
Info	Informational	http://127.0.0.1	Percentage of endpoints with method POST	7 %
Info	Informational	http://127.0.0.1	Count of total endpoints	13
Info	Informational	https://127.0.0.1	Percentage of endpoints with method GET	100 %
Info	Informational	https://127.0.0.1	Count of total endpoints	1
Info	Informational	https://api.github.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://api.github.com	Percentage of slow responses	100 %
Info	Informational	https://avatars.githubusercontent.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://avatars.githubusercontent.com	Percentage of slow responses	28 %
Info	Informational	https://camo.githubusercontent.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://camo.githubusercontent.com	Percentage of slow responses	83 %
Info	Informational	https://collector.github.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://collector.github.com	Percentage of slow responses	100 %
Info	Informational	https://github.com	Percentage of responses with status code 2xx	93 %
Info	Informational	https://github.com	Percentage of responses with status code 4xx	6 %
Info	Informational	https://github.com	Percentage of slow responses	57 %
Info	Informational	https://github.githubassets.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://github.githubassets.com	Percentage of slow responses	6 %

Alerts

1. **Risk=Medium, Confidence=High (2)**
    1. **http://127.0.0.1 (2)**
        1. **Content Security Policy (CSP) Header Not Set (1)**
            1. ▶ GET http://127.0.0.1/robots.txt
        2. **Hidden File Found (1)**
            1. ▶ GET http://127.0.0.1/dvwa/.git/config
2. **Risk=Medium, Confidence=Medium (3)**
    1. **http://127.0.0.1 (2)**
        1. **Directory Browsing (1)**
            1. ▶ GET http://127.0.0.1/dvwa/dvwa/images/

2. **Missing Anti-clickjacking Header** (1)

    1. ▶ GET http://127.0.0.1/dvwa

3. **Risk=Low, Confidence=High (2)**

    1. **http://127.0.0.1 (2)**

        1. **In Page Banner Information Leak** (1)

            1. ▶ GET http://127.0.0.1/robots.txt

        2. **Server Leaks Version Information via "Server" HTTP Response Header Field** (1)

            1. ▶ GET http://127.0.0.1/dvwa

4. **Risk=Low, Confidence=Medium (3)**

    1. **http://127.0.0.1 (3)**

        1. **Big Redirect Detected (Potential Sensitive Information Leak)** (1)

            1. ▶ GET http://127.0.0.1/dvwa

        2. **Cookie without SameSite Attribute** (1)

            1. ▶ GET http://127.0.0.1/dvwa/

        3. **X-Content-Type-Options Header Missing** (1)

            1. ▶ GET http://127.0.0.1/dvwa

5. **Risk=Informational, Confidence=High (1)**

    1. **http://127.0.0.1 (1)**

        1. **Authentication Request Identified** (1)

            1. ▶ POST http://127.0.0.1/dvwa/login.php

6. **Risk=Informational, Confidence=Medium (2)**

    1. **http://127.0.0.1 (2)**

        1. **Session Management Response Identified** (1)

            1. ▶ GET http://127.0.0.1/dvwa/

        2. **User Agent Fuzzer** (1)

1. ▶ GET http://127.0.0.1/dvwa/

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

1. **Content Security Policy (CSP) Header Not Set**

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	1. https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP 2. https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html 3. https://www.w3.org/TR/CSP/ 4. https://w3c.github.io/webappsec-csp/ 5. https://web.dev/articles/csp 6. https://caniuse.com/#feat=contentsecuritypolicy 7. https://content-security-policy.com/

2. **Directory Browsing**

Source	raised by an active scanner (Directory Browsing)
CWE ID	548
WASC ID	48
Reference	1. https://httpd.apache.org/docs/current/mod/core.html#options

3. **HTTP Only Site**

Source	raised by an active scanner (HTTP Only Site)
CWE ID	311
WASC ID	4
Reference	1. https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html 2. https://letsencrypt.org/

4. **Hidden File Found**

Source	raised by an active scanner (Hidden File Finder)
CWE ID	538
WASC ID	13
Reference	1. https://blog.hboeck.de/archives/892-Introducing-Snallygaster-a-Tool-to-Scan-for-Secrets-on-Web-Servers.html 2. https://git-scm.com/docs/git-config

5. **Missing Anti-clickjacking Header**

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021

WASC ID 15

Reference
1. https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

6. **Big Redirect Detected (Potential Sensitive Information Leak)**

Source raised by a passive scanner (Big Redirect Detected (Potential Sensitive Information Leak))
CWE ID 201
WASC ID 13

7. **Cookie without SameSite Attribute**

Source raised by a passive scanner (Cookie without SameSite Attribute)
CWE ID 1275
WASC ID 13
Reference
1. https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

8. **In Page Banner Information Leak**

Source raised by a passive scanner (In Page Banner Information Leak)
CWE ID 497
WASC ID 13
Reference
1. https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/08-Testing_for_Error_Handling/

9. **Server Leaks Version Information via "Server" HTTP Response Header Field**

Source raised by a passive scanner (HTTP Server Response Header)
CWE ID 497
WASC ID 13
Reference
1. https://httpd.apache.org/docs/current/mod/core.html#servertokens
2. https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10)
3. https://www.troyhunt.com/shhh-dont-let-your-response-headers/

10. **X-Content-Type-Options Header Missing**

Source raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID 693
WASC ID 15
Reference
1. https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)
2. https://owasp.org/www-community/Security_Headers

11. **Authentication Request Identified**

Source raised by a passive scanner (Authentication Request Identified)
Reference
1. https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/

12. **Session Management Response Identified**

Source raised by a passive scanner (Session Management Response Identified)

Reference 1. https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/

13. **User Agent Fuzzer**

Source raised by an active scanner (User Agent Fuzzer)

Reference 1. https://owasp.org/wstg